

הנדון: נספח אבטחת מידע - להסכם מיקור חוץ לספקים חיצוניים

1. אבטחה פיזית וסביבתית

- 1.1. תיושם בקרת גישה פיזית לחדר בו מאוחסן המידע המגיע לאקים ישראל (להלן – אקים).
AIVOTA: לא ניתן לקבל גישה פיזית לשרתי AWS באזור ישראל (il-central-1). מדיניות האבטחה הגלובלית והקשיחה של AWS אוסרת באופן מוחלט על לקוחות, שותפים עסקיים או אנשי קשר חיצוניים להיכנס פיזית לחוות השרתים (Data Centers) שלה.
- 1.2. הספק יקיים בכל עת נהלים ומדיניות להגנה ואבטחה פיזית של המידע ויציג אותם לאקים על פי דרישתה.
AIVOTA: מקובל
- 1.3. הספק ימדר את הגישה הפיזית למידע של אקים (ע"ב הצורך למידע) ויישם מנגנוני בקרה באמצעות אמצעי הזדהות.
AIVOTA: מקובל

2. מהימנות, הרשאות גישה לעובדים ומידור

- 2.1. למידע המגיע מאקים או מלקוחותיה תתאפשר גישה רק לעובדים הכרחיים ומורשים.
- 2.2. הספק יקיים נהלי אבטחת מידע שיכללו בין השאר: הקצאת הרשאות ובקרתן, אחריות העובד לאבטחת מידע, ויציג את הנהלים למחלקת אבטחת מידע של אקים על פי דרישתה מעת לעת.
- 2.3. הספק יקיים תכנית לשמירה והעלאת מודעות עובדים לנושאי אבטחת מידע בדגש על עובדים הנגשים למידע של אקים.
- 2.4. הספק יוודא כי כל עובד, קבלן משנה או גורם מטעמו אשר ניתנת לו גישה למידע של העמותה במסגרת מתן השירותים, יחתום טרם קבלת הגישה למידע על התחייבות לשמירת סודיות והגנה על המידע. התחייבות זו תכלול שמירה על סודיות המידע, שימוש במידע אך ורק לצורך מתן השירותים, ואיסור העברת המידע או גילוי לגורם שאינו מורשה.
- 2.5. בנוסף, הספק יוודא כי התחייבות הסודיות הנחתמת על ידי עובדיו תכלול רמת הגנה והתחייבויות שאינן פחותות מרמת ההגנה והדרישות המפורטות במסמך אבטחת מידע זה, וכן תעמוד בדרישות הרלוונטיות הקבועות בתקנות הגנת הפרטיות. הספק יהיה אחראי לפקח ולוודא כי עובדיו מודעים להתחייבויות אלה ופועלים בהתאם להן לאורך כל תקופת עבודתם.
- 2.6. במידע המגיע מאקים או מלקוחותיה ייעשה שימוש אך ורק בהתאם לצורכי עבודה אשר בגינם התקבל המידע.
- 2.7. הספק יישם מנגנוני גישה טכנולוגיים ופיזיים על מנת לאכוף את בקרת הגישה, בהתאם לדרישות אקים כפי שתימסרנה לספק מעת לעת, ולפי כל דין.
- 2.8. הספק יאכוף שלילת גישה לעובד שאינו נדרש יותר בגישה למידע של אקים.

3. מידע של אקים המועבר לספק

בטבלה הנ"ל מפורט המידע שיועבר מאקים אל הספק, במסגרת שיתוף הפעולה (פרטי מחזיקי כרטיס, שמות לקוחות, אימיילים, מספרי ת.ז, מספרי כרטיסי אשראי, כתובות IP וכו'), לרבות כמות מידע מוערכת שתהיה שמורה אצל הספק ואיזו פעילות הספק יעשה עם המידע:

פרט המידע המועבר	כמות מוערכת	הסבר לצורך העברת המידע (שימוש)	הערות נוספות

4. תהליך העברת המידע

- במהלך ההתקשרות יועבר מידע בין אקים לספק, ועל כן נדרש לקיים את ההנחיות הבאות:
- 4.1 תווך התקשורת יוצפן למניעת שינוי המידע ולמניעת האזנה, בפרוטוקול סטנדרטי ועדכני (לדוגמה: TLS בגרסה עדכנית).
 - 4.2 יתקיים זיהוי ואימות חזק של הצדדים המתקשרים (לדוגמה: באמצעות תעודה דיגיטלית).
 - 4.3 תצורת הממשק תאושר על ידי מנהל מערכות המידע של אקים.
 - 4.4 לא תבוצע כל העברת מידע של אקים או כל חומר רגיש אחר באופן גלוי באמצעות רשת האינטרנט.
 - 4.5 צורת העברת המידע בצורה פיזית, תאושר ע"י אקים, לרבות מדיה מגנטית, ניירת וכדומה.

5. אבטחת המידע במערכות הספק בהן יאוחסן המידע המגיע מאקים

- 5.1 הספק מתחייב לקיומה של רמת אבטחה גבוהה ומקובלת בכל שרשרת אספקת השירות, ומתחייב לבצע ביקורות על ספקי המשנה שלו (ככל שישנם) על מנת לוודא עמידתם באחד או יותר מתקני האבטחה המקובלים.
- 5.2 יש למנות נאמן אבטחת מידע מטעם הספק:

שם מלא	טלפון	כתובת מייל

- 5.3 על הספק להציג רשימת ספקי צד ג' שלו, אשר תומכים בשירותים הניתנים לאקים:

שם הספק	השירות אותו מספק הספק	המידע של אקים אליו נחשף הספק

- 5.4 הספק מתחייב שלא לחשוף את המידע שמתקבל מאקים לספקי משנה ו/או בין פרויקטים שונים של הספק ללא אישור מראש של אקים.
- 5.5 במקרים שאושר ע"י אקים שימוש בספקי משנה, על הספק מוטלת האחריות לוודא את עמידת ספקי המשנה בדרישות אבטחת המידע שבנספח זה וחתימתם עליו או לקבל הסכמה מפורשת מראש של אקים לתנאי אבטחת המידע של ספק המשנה.
- 5.6 תבוצע חציצה (לא תהיה גישה ישירה) בין המערכות המעבדות מידע הקשור לאקים לבין ממשקים חיצוניים, בעיקר קישור לאינטרנט.
- 5.7 גישה מרחוק למידע של אקים המאוחסן אצל הספק תתאפשר לאחר אישור מנהל אבטחת מידע באקים ואך ורק למשתמשים הנדרשים לכך במסגרת תפקידם. בנוסף, תבוצע בקרה על פעילות מרחוק ויבוצע רישום של פעולות המשתמש.
- 5.8 חייוי ובקרה – יישמר Log רישום פעולות הנעשות במידע של אקים ומערכות קשורות. הרישום יישמר למשך 6 חודשים. הלוג יכיל לכל הפחות: זיהוי של מבצע הפעולה, הפעולה שבוצעה, ערך ששונה (כשרלוונטי) ו-Time Stamp.
- 1.1 מידע של אקים יישמר בספריות ייעודיות עבור פרויקט אקים בלבד. לספריות אלה תתאפשר גישה לעובדים מורשים בלבד הרלוונטיים לביצוע הפרויקט וזאת באמצעות סיסמה אישית.

1.1. אין לשמור מידע של אקים בתיקיות מקומיות על גבי תחנות העבודה וחל איסור לשמור מידע של אקים על גבי מחשבים ניידים של הספק. צורך חריג יובא לאישור מנהל מערכות המידע של אקים.

1.1.1. יאובטחו המערכות בהן יאוחסן ויעובד המידע על פי הסטנדרטים המקובלים לאבטחת מידע. בין היתר יתקיימו:

5.11.1. נהלי בקרת גישה – הגבלת רשימת מורשי הגישה למערכת, זיהוי ואימות המשתמש לפני מתן גישה למידע, מדיניות סיסמאות מתאימה וכדומה.

5.11.2. לא יבוצע שימוש בחשבון Administrator בשגרה או בכל משתמש כללי אחר, אלא יבוצע שימוש בחשבון האישי של כל אחד מעובדי הספק

5.11.3. הסרת שירותים מיותרים ועדכון המערכות בהתאם לסטנדרטים המקובלים

5.11.4. מערכות הפעלה בשרתים ובתחנות העבודה יוקשחו ויותקנו בהם עדכונים אבטחת מידע על בסיס שוטף וקבוע.

5.11.5. תבוצע הפרדה בין מערכות ייצור לבין מערכות בדיקות/פיתוח, וכן אינטגרציה במידת הצורך תתבצע מול סביבה תואמת.

5.11.6. ייעשה שימוש במערכות מניעת וירוסים וקוד זדוני במחשבי הספק. לדוגמה: EDR או אנטי וירוס

2. פיתוח מאובטח

ככל שבמסגרת ההתקשרות עם אקים מבוצע תהליך של פיתוח תוכנה/אפליקציה/עדכון גרסת מערכת, יש להקפיד שהפיתוח יבוצע בתהליך "פיתוח מאובטח" (SDLC) בהתאם לנהלי פיתוח המקובלים בתעשייה.

3. המצאת אישורים

הספק יעביר לאקים אישורים ככל שיידרש (במידה וקיימים), לגבי בדיקות אבטחה שנערכו אצל הספק בעבר כגון: בדיקות חדירות למערכות המידע הקשורות במידע המגיע מאקים, בדיקת אתר האינטרנט, בדיקת אפליקציות בהן נעשה שימוש הנוגע למידע המגיע מאקים וכדומה.

4. ביקורת

נציגי אבטחת מידע של אקים יקבלו אישור לבצע ביקורת אצל הספק ככל שיידרש, ביקורת הקשורה למידע המגיע לספק לרבות – מידור, תצורת שרתים, הרשאות גישה, משתמשים, נהלי שינוע המידע, בסיסי נתונים, שימוש במידע באתר האינטרנט וכו', תבוצע בתיאום מראש, תוך תיאום ציפיות מלא עם אקים.

5. עדכון לגבי שינויים

חובת הספק להעביר דיווח לאבטחת מידע באקים לגבי שינויים הנעשים אצלו ועלולים להשפיע על אבטחת המידע של אקים המאוחסן אצל הספק. לדוגמה שינויים במערכות, נהלים, אבטחה פיסית, שימוש במחשוב ענן, שינוי גאוגרפי בחוות האחסון וכדומה.

6. חריגים ודיווחים

1.1. כל מקרה של אירוע חריג או חשד לאירוע חריג הנוגע לאבטחת מידע או אבטחה פיסית, העלולים לסכן את המידע השייך לאקים, יועבר דיווח לאבטחת מידע באקים.

1.2. על הספק להציג לאקים מוכנות לטיפול באירועי אבטחת מידע, בין השאר בקיומם של מסמכי מדיניות ונהלים לטיפול באירועי אבטחת מידע, לפי דרישה.

1.3. במקרה של אירוע אבטחת מידע, על הספק להעביר למחלקת אבטחת מידע של אקים תחקיר אירוע הכולל: תיאור האירוע, מסקנות והמלצות שיושמו, בתוך זמן סביר ממועד סיום האירוע, ולא יאוחר מ- 3 ימים ממועד סיום האירוע, או במועד מאוחר יותר, בהתאם לסוג האירוע.

1.4. על הספק לדווח מיידית לאקים, בעל פה ובמקביל גם בכתב, על כל אירוע אבטחת מידע ו/או סייבר, לרבות פגיעה ו/או חשיפה בלתי מורשית ו/או חדירה לנתוני לקוחות ו/או נתונים של אקים המתרחשת במערכותיו של הספק ו/או אצל ספקי משנה שלו, וזאת בתוך 48 שעות.

1.5. מבלי לגרוע מחובתו של הספק על פי דין ועל פי ההסכם עם אקים על נספחיו, על הספק תחול חובת דיווח מידית לאקים על אירועי אבטחת מידע משמעותיים שהתרחשו בחצרותיו. כגון: פריצה למאגרי מידע, התפשטות וירוס/נוזקה, אי זמינות מערכות מידע וכד'.

1.6. הספק מתחייב להודיע לאקים על כל פנייה שתגיע בעניין קבלת זכות עיון או תיקון של מידע שברשותו של הספק בתוך 72 שעות מרגע קבלתה. בכפוף להוראות כל דין, הספק יענה לפניית נושא המידע רק לאחר שהתקבל אישור בכתב מאקים ובהתאם להנחיותיה.

2. כרטיסי אשראי

במידה והספק יספק לאקים שירות במסגרתו ישמר, יעובד ו/או יועבר מידע של כרטיסי אשראי, חלה עליה עמידה בדרישות תקן אבטחת מידע של כרטיסי האשראי (PCI DSS).

3. מחשוב ענן

במידה ובמסגרת ההתקשרות יסופק לאקים שירות המבוסס על מחשוב ענן (הספק משתמש בשירותי מחשוב ענן או במידה והספק בעצמו הוא ספק שירותי מחשוב ענן), גם אם בצורה חלקית, חלות עליו ההנחיות הבאות:

3.1. חובת הספק להודיע לאקים על כל שינוי משמעותי הצפוי במחשוב הענן, תשתית מחשוב הענן ולא ספקי הענן.

3.2. ככלל, מידע של אקים אשר יאוחסן במחשוב ענן יישמר בצורה מוצפנת, אלא אם מדובר במידע פומבי או שהתקבל אישור לא להצפין ע"י אבטחת מידע באקים.

3.3. הנחיות עבור גישה לתשתית המערכות המאוחסנות בשירות הענן, לרבות בסיסי נתונים, מערכות ניהול וירטואליזציה ותשתית, אשר מכילים מידע של אקים:

3.3.1. תוגבל ותותר אך ורק מרשת הספק.

3.3.2. תותר ע"פ צורך בלבד.

3.3.3. תישם הזדהות חזקה.

4. מידע במנוחה והצפנה

4.1. הספק מתחייב כי כל מידע של אקים המאוחסן במערכותיו, לרבות מסדי נתונים, קבצים, גיבויים ומידע בכל מדיה דיגיטלית אחרת – יישמר במצב מוצפן (Data at Rest Encryption).

4.2. ההצפנה תתבצע באמצעים מוכרים ומקובלים בתעשייה, כגון: AES-256 או אלגוריתם הצפנה חזק ושווה ערך, בהתאם לסטנדרטים בינלאומיים עדכניים.

4.3. ניהול מפתחות ההצפנה יתבצע באופן מאובטח, תוך שימוש במנגנוני HSM (Hardware Security Module) או שירות ניהול מפתחות מאובטח בענן (KMS), לרבות הפרדת תפקידים בין בעלי הרשאות ניהול.

4.4. גיבויים פיזיים ודיגיטליים של מידע של אקים יישמרו כשהם מוצפנים, והגישה אליהם תותר אך ורק לעובדים מורשים שנקבעו מראש.

4.5. חל איסור מוחלט לשמור מידע של אקים במצב גלוי (Plaintext) על תחנות קצה, מחשבים ניידים או אמצעי אחסון ניידים, אלא אם התקבל אישור בכתב מאבטחת המידע של אקים.

4.6. כל מדיה פיזית המכילה מידע של אקים (כגון כוננים קשיחים, דיסקים, קלטות גיבוי) תישמר בהצפנה ותושמד בסיום השימוש בהתאם לנהלי השמדה מאובטחת.

5. העברת מידע מחוץ לישראל

5.1. הספק מתחייב כי מידע של אקים לא יועבר, לא יישמר ולא תהיה אליו גישה מחוץ לישראל, אלא באישור מראש ובכתב מאבטחת המידע של אקים.

- 5.2. ככל שאושר להעביר מידע אל מחוץ לישראל, הספק מתחייב לעמוד בכל הוראות הדין החל, לרבות:
- 5.3. הוראות חוק הגנת הפרטיות והנחיות רשות הגנת הפרטיות בישראל;
- 5.4. דרישות רגולציה בינלאומיות החלות על המידע, ככל שהן רלוונטיות, כגון תקנות ה-GDPR באיחוד האירופי או רגולציית HIPAA בארצות הברית. שימוש במנגנוני Transfer Impact Assessment (SCCs) (Standard Contractual Clauses) או (TIA) (Transfer Impact Assessment) כאשר נדרש.
- 5.5. הספק יוודא כי כל צד ג' בחו"ל המקבל מידע של אקים חותם על הסכם מחמיר הכולל את כל הוראות אבטחת המידע והפרטיות הנדרשות על פי דין ועל פי נספח זה.
- 5.6. האחריות המלאה, הבלעדית וללא תנאי לעמידה בדרישות רגולציה והסכמים תחול על הספק, גם אם העברת המידע בוצעה באמצעות קבלני משנה.

6. אירועי אבטחת מידע

- 6.1. מובהר בזאת כי הספק יישא במלוא האחריות לכל אירוע אבטחת מידע או אירוע סייבר שיתרחש במערכתיו או במערכות קבלני המשנה שלו, אשר עלול להשפיע על מידע של אקים.
- 6.2. הגבלת האחריות של הספק בהתאם להסכם ההתקשרות לא תגרע מהחובות המפורטות בנספח זה או על פי כל דין, ולא תהווה עילה לפטור מאחריות לנזק שייגרם בפועל לאקים כתוצאה מאירוע אבטחת מידע.
- 6.3. הספק מתחייב לנקוט בכל האמצעים הסבירים למניעת אירועי אבטחת מידע, וכן להודיע לאקים באופן מיידי על כל אירוע אבטחת מידע, בהתאם להוראות נספח זה.

7. שיפוי ופיצוי

- 7.1. במקרה של אירוע אבטחת מידע שגרם לנזק ישיר או עקיף לאקים, הספק מתחייב לשפות ולפצות את אקים בגין כל נזק, הפסד, הוצאה, תביעה או דרישה שתוגש כנגדה.
- 7.2. השיפוי יכלול בין היתר: עלויות חקירת האירוע, עלויות תיקון ושיקום, קנסות ועיצומים מנהליים שהוטלו על אקים, פיצוי לנושאי מידע, הוצאות משפט ושכר טרחת עורכי דין.
- 7.3. הספק יישא באחריות מלאה גם כלפי אירועי אבטחת מידע שנגרמו כתוצאה ממעשים או מחדלים של עובדיו, נציגיו או קבלני המשנה מטעמו.

8. סיום ההתקשרות

- 8.1. עם סיום ההתקשרות בין הצדדים, מכל סיבה שהיא, הספק יפסיק לאלתר כל שימוש במידע של אקים ויפעל בהתאם להנחיות אקים באשר להחזרת המידע או מחיקתו.
- 8.2. בהתאם להנחיות אקים, הספק יחזיר לאקים את כל המידע, המסמכים, הקבצים והנתונים השייכים לאקים המצויים בידיו או בשליטתו, לרבות עותקים, גיבויים וכל מידע נגזר מהם, או לחלופין ימחקם באופן מאובטח כך שלא ניתן יהיה לשחזרם.
- 8.3. מחיקת המידע תבוצע באמצעים מקובלים בתעשייה להשמדה מאובטחת של מידע, לרבות מחיקה לוגית והשמדה פיזית של מדיה בצורך.
- 8.4. הספק יעביר לאקים, לפי דרישתו, אישור בכתב בדבר השלמת מחיקת המידע והשמדתו, לרבות מידע המצוי אצל קבלני משנה מטעמו.
- 8.5. הספק יוודא כי גם כל ספק משנה או צד שלישי שקיבל גישה למידע של אקים במסגרת מתן השירותים פועל בהתאם להוראות סעיף זה ומחזיר או משמיד את המידע כאמור.
- 8.6. הוראות סעיף זה ימשיכו לחול גם לאחר סיום ההתקשרות בין הצדדים, ככל שהדבר נדרש לצורך שמירה על סודיות ואבטחת המידע של אקים.

9. טיפול בפניות נושאי מידע

- 9.1. ככל שהספק מקבל במסגרת מתן השירותים מידע אישי הנוגע לנושאי מידע, הספק מתחייב לפעול בהתאם להוראות חוק הגנת הפרטיות והתקנות מכוחו בכל הנוגע לטיפול בפניות של נושאי מידע.
- 9.2. הספק לא יענה באופן עצמאי לפנייה של נושא מידע המבקש לממש זכויותיו ביחס למידע אישי (לרבות זכות עיון, תיקון, מחיקה או כל זכות אחרת), אלא לאחר קבלת הנחיה מפורשת ובכתב מאקים.
- 9.3. הספק מתחייב להעביר לאקים כל פנייה של נושא מידע שהתקבלה אצלו, הנוגעת למידע של אקים, בתוך 72 שעות ממועד קבלתה, ולכלול בפנייה את כל הפרטים הרלוונטיים הידועים לו.
- 9.4. הספק ישתף פעולה עם אקים ככל שיידרש לצורך טיפול בפניות נושאי מידע, לרבות איתור המידע הרלוונטי, הפקתו, תיקונו או מחיקתו בהתאם להנחיות אקים.
- 9.5. הספק מתחייב ליישם מגננים ארגוניים וטכנולוגיים שיאפשרו איתור, שליפה וטיפול במידע אישי של נושאי מידע במידה שתידרש פעולה כאמור.

10. שמירת הוראות הדין

הספק מצהיר ומתחייב, מבלי לגרוע מן האמור בנספח זה, כי הוא עומד וימשיך לעמוד במשך כל תקופת ההתקשרות עם אקים בכלל הוראות חוק הגנת הפרטיות, התשמ"א-1981 ובתקנות הגנת הפרטיות (אבטחת מידע), התשע"ז-2017.

אנו מתחייבים לקיים את כל דרישות אבטחת המידע המפורטות בנספח זה

ולראיה באתי על החתום ביום _____ לחודש _____ בשנת _____

שם החותם: _____

מס' ת"ז: _____

תפקיד: _____

כתובת הספק: _____

שם הספק: _____

טלפון במשרד: _____

טלפון נייד: _____

חתימה: _____

